

ShopSphere

S13 - Payments, Gateway Verification and Idempotency

Backend + DB

Platform-Specific Sprint Planning Document

This document intentionally defines only the behavior and delivery scope of the selected platform. It does not mix implementation details from the other platforms.

1. Sprint Definition

Sprint: S13 - Payments, Gateway Verification and Idempotency

Platform: Backend + DB

Application: ShopSphere

Objective: Implement the backend and database boundary for Payments, Gateway Verification and Idempotency, including business rules, persistence and API behavior.

This sprint is complete only when the stated use cases, acceptance criteria and tests pass for this platform.

2. Business Use Cases

ID	Use Case	Actor	Precondition	Main Flow	Expected Result
UC-01	Pay order	Customer	Valid checkout	Create payment, complete gateway flow, verify callback	Order/payment reaches a confirmed server state.
UC-02	Process webhook	Gateway	Authentic webhook	Verify signature and idempotency, update payment	Duplicate/replayed webhook has no duplicate effect.

3. Detailed Implementation Plan

1. Integrate chosen payment gateway.
2. Create payment order and callback/webhook verification.
3. Verify signatures/authenticity and prevent replay.
4. Implement retry/timeout/idempotency.
5. Never store raw card data.

4. Data / State / Contract Scope

- payments
- payment_transactions

API / Integration Contract

- Feature APIs for this sprint, versioned under /api/v1.
- Every endpoint must define authentication, authorization, validation, error codes and request correlation.

5. Rules and Expected Behavior

- The platform must rely on the backend as the source of truth for business rules.
- Do not expose stack traces, secrets or internal implementation details to end users.
- Handle loading, empty, validation and error states explicitly.
- Requests that can be retried must be safe from duplicate side effects where the feature requires idempotency.
- Ownership and authorization must be checked server-side for protected data.

6. Acceptance Criteria

- Data model supports the required business relationships and constraints.
- API enforces authentication, authorization, validation and ownership where applicable.
- Business rules are server-authoritative.
- Transactions/idempotency/concurrency controls are used where the feature requires them.
- Controlled error codes and request correlation are implemented.

7. Test Cases

TC	Scenario	Expected Result
TC-S13-01	Gateway timeout	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S13-02	Duplicate webhook	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S13-03	Forged signature	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S13-04	Payment success then app closes	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S13-05	Debited but callback timeout	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S13-06	Retry after timeout	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S13-07	Duplicate payment request	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S13-08	COD unavailable	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.

8. Sprint Exit Checklist

- Implementation completed only for this platform.
- All primary and negative use cases pass.
- API contracts are implemented/consumed as defined.
- Validation and authorization tests pass.
- Loading/empty/error handling is verified where applicable.
- No critical or blocker defect remains.
- Automated tests pass in CI.
- Documentation and contract changes are committed.

9. Out of Scope for This Document

- Implementation behavior of Customer Portal. That behavior belongs in the separate S13 document for that platform.
- Implementation behavior of Admin Portal. That behavior belongs in the separate S13 document for that platform.